

NETWORK SCANNING AND ANALYSIS

OBJECTIVE:

The objective of network scanning and analysis is to identify open ports, running services, web directories, server configurations, and insecure communication channels without actively exploiting any vulnerability.

This phase helps to understand what services are exposed and how the target system is configured, and it is performed after Reconnaissance and before Exploitation.

LAB ENVIRONMENT:

- Attacker Machine: Kali Linux
- Target Machine: Ubuntu Linux running DVWA
- Target IP: 192.168.100.10
- Application: Damn Vulnerable Web Application (DVWA)

TOOLS USED:

- Nmap
- Gobuster
- Nikto
- Wireshark

(1)NMAP (NETWORK MAPPER):

Nmap is used to:

- Discover open network ports
- Identify running services
- Detect service versions
- Identify the operating system

This information helps to determine potential attack surfaces.

Command Used:

```
nmap -sS -sV -O 192.168.100.10
```

Command Explanation:

- sS → SYN (Stealth) Scan
- sV → Service Version Detection
- O → Operating System Detection

```
File Machine View Input Devices Help
kali@kali: ~
64 bytes from 192.168.100.10: icmp_seq=6 ttl=64 time=1.03 ms
64 bytes from 192.168.100.10: icmp_seq=7 ttl=64 time=1.83 ms
64 bytes from 192.168.100.10: icmp_seq=8 ttl=64 time=1.39 ms
^Z
zsh: suspended ping 192.168.100.10

(kali@kali)~]
$ nmap -sS -sV -O 192.168.100.10
Starting Nmap 7.98 ( https://nmap.org ) at 2026-01-02 06:55 -0500
Nmap scan report for 192.168.100.10
Host is up (0.00076s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
80/tcp    open  http      Apache httpd 2.4.58 ((Ubuntu))
MAC Address: 08:00:27:9A:51:4C (Oracle VirtualBox virtual NIC)
Device type: general purpose/router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kernel:5.6.3
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3)
Network Distance: 1 hop

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.37 seconds

(kali@kali)~]
$
```

Observation:

- The scan confirms that the target host is active and reachable
- Open port is identified along with its state and running version
- Service version information is disclosed for the detected service
- The operating system details, including OS CPE and OS version is detected
- The network distance indicates the target is reachable within local network

OWASP Mapping:

A02:2025 – Security Misconfiguration

- Database service exposed
- Unrestricted service access
- Default Apache configuration

(2)GOBUSTER:

Gobuster is used to:

- Discover hidden directories and files
- Identify sensitive pages
- Reveal administrative or setup endpoints

Command Used:

```
gobuster dir -u http://<UBUNTU-IP>/DVWA/ -w /usr/share/wordlists/dirb/common.txt
```

Command Explanation:

Dir → Directory enumeration mode

-u → Target URL

-w → Wordlist for directory guessing

```
(kali@kali)~$ gobuster dir -u http://192.168.100.10/DVWA/ -w /usr/share/wordlists/dirb/common.txt

Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.100.10/DVWA
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

./hta (Status: 403) [Size: 279]
./git/HEAD (Status: 200) [Size: 23]
./htaccess (Status: 403) [Size: 279]
./htpasswd (Status: 403) [Size: 279]
/config (Status: 301) [Size: 322] [→ http://192.168.100.10/DVWA/config/]
/database (Status: 301) [Size: 324] [→ http://192.168.100.10/DVWA/database/]
/docs (Status: 301) [Size: 320] [→ http://192.168.100.10/DVWA/docs/]
/external (Status: 301) [Size: 324] [→ http://192.168.100.10/DVWA/external/]
/favicon.ico (Status: 200) [Size: 1406]
/index.php (Status: 302) [Size: 0] [→ login.php]
/php.ini (Status: 200) [Size: 154]
/phpinfo.php (Status: 302) [Size: 0] [→ login.php]
/robots.txt (Status: 200) [Size: 25]
/tests (Status: 301) [Size: 321] [→ http://192.168.100.10/DVWA/tests/]
Progress: 4613 / 4613 (100.00%)

Finished
```

Observation:

- Directory enumeration was performed on the target URL using Gobuster
- The scan parameters such as wordlist, threads, method and timeout were applied
- Hidden directories on the target application were identified

OWASP Mapping:

A02:2025 – Security Misconfiguration

Sensitive pages exposed

Lack of access control

Setup files accessible publicly

(3)NIKTO:

Nikto scans the web server for:

- Misconfigurations
- Missing security headers
- Outdated components
- Information disclosure

Nikto automatically checks thousands of known web server issues.

Command Used:

```
nikto -h http://192.168.100.10
```

Command Explanation:

-h → Target host



```
kali@kali: ~  
Session Actions Edit View Help  
(kali@kali)~$ nikto -h http://192.168.100.10  
- Nikto v2.5.0  
  
+ Target IP: 192.168.100.10  
+ Target Hostname: 192.168.100.10  
+ Target Port: 80  
+ Start Time: 2026-01-02 07:18:34 (GMT-5)  
  
+ Server: Apache/2.4.58 (Ubuntu)  
+ /: The anti-clickjacking X-Frame-Options header is not present.  
See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options  
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/  
+ No CGI Directories found (use '-C all' to force check all possible dirs)  
+ /: Server may leak inodes via ETags, header found with file /, inode: 29af, size: 64739b2447ff6, mtime: gzip. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418  
+ OPTIONS: Allowed HTTP Methods: GET, POST, OPTIONS, HEAD .  
+ 8103 requests: 0 error(s) and 4 item(s) reported on remote host  
+ End Time: 2026-01-02 07:18:45 (GMT-5) (11 seconds)  
  
+ 1 host(s) tested  
  
*****  
*****  
Portions of the server's headers (Apache/2.4.58) are not in the Nikto 2.5.0 database or are newer than the known string. Would you like to submit this information (*no server specific data*) to CI RT.net for a Nikto update (or you may email to sullo@cirt.net) (y/n)? n
```

Observation:

- Nikto was executed against the target IP and specified web server ports
- The scan identified the web server type running on the target host
- Missing security headers and potential information disclosure were detected
- The scan revealed the HTTP methods allowed by the server

OWASP Mapping:

A02:2025 – Security Misconfiguration

- Missing security headers
- Information leakage
- Default server settings

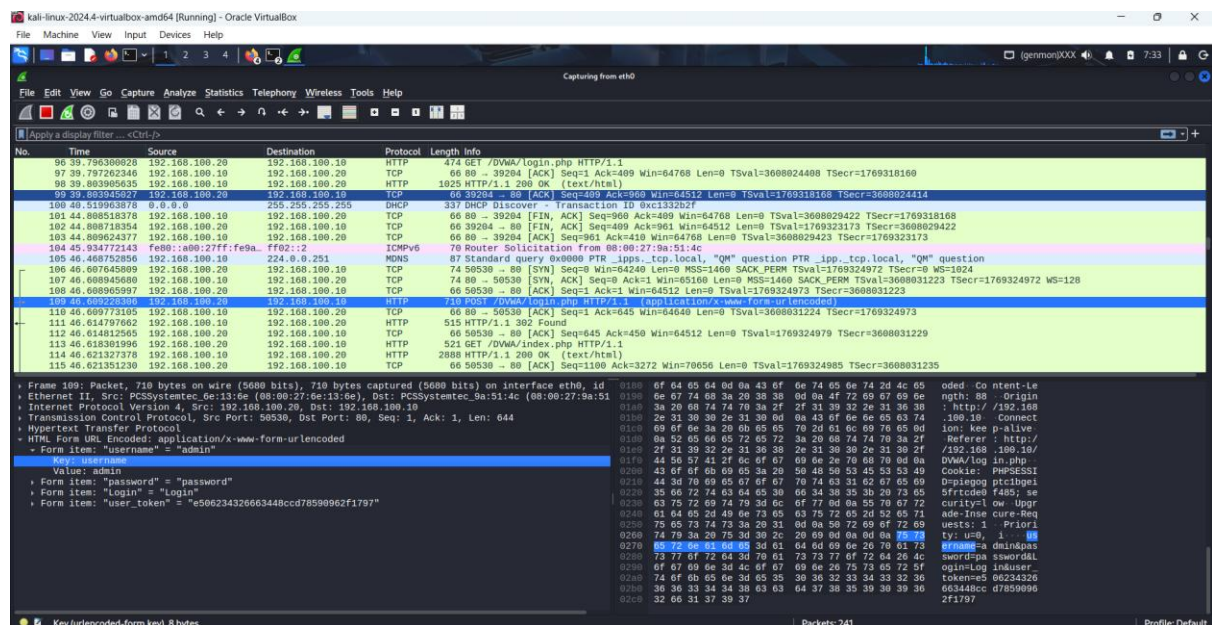
(4)WIRESHARK:

Wireshark is used to:

- Observe network traffic
- Detect plaintext credentials
- Identify encryption weaknesses

Observed Traffic:

- HTTP POST login requests
- Usernames and passwords transmitted in clear text



Observation:

- Network traffic between the source and destination hosts was successfully captured
- Packet details such as time, source IP, destination IP, protocol and packet length observed
- Sensitive information including username, password and user token was visible in the captured packet
- This indicates that the data was transmitted in plain text over the network

OWASP Mapping:**A04:2025 – Cryptographic Failures**

- No HTTPS
- Sensitive data in plaintext
- Lack of encryption mechanisms

CONCLUSION:

During network scanning and analysis, multiple assessment tools were used to identify exposed services, insecure configurations, and unsafe data transmission within the DVWA lab environment. Nmap revealed open HTTP and database services, Gobuster identified sensitive web directories, Nikto detected web server misconfigurations, and Wireshark confirmed plaintext credential transmission. These findings indicate multiple security weaknesses aligned with OWASP Top 10, primarily A02:2025 Security Misconfiguration and A04:2025 Cryptographic Failures.